PROCEDIMENTO DE CONFIGURAÇÃO DEVSECOPS: ANÁLISE DE IMAGENS DE CONTÊINERES - TRIVY

INTRODUÇÃO

Este guia detalha o procedimento para realizar o scan standalone de imagens de contêineres utilizando o Trivy. É possível adotar o Trivy no Pipeline DevOps, contudo, não será abordado neste documento.

IMPORTANTE: O procedimento a seguir considera as URLs, interfaces e versões fornecidas pelos fabricantes na data corrente da escrita deste documento. Em caso de mudanças no processo, por favor, verifique o processo semelhante.

PROCEDIMENTO TÉCNICO

1. Instalação do Docker

Antes de escanear imagens, requer-se instalar o Docker. Se você já tem o Docker Desktop (ou Docker Engine) instalado, pode desconsiderar esta parte. Para a maioria dos ambientes de desenvolvimento em laptop (Windows, MacOS ou Linux), uma opção amplamente adotada é o Docker Desktop. Abaixo, será considerado este processo. Para tanto:

- Acesse o site oficial: https://www.docker.com/products/docker-desktop/
- Baixe o instalador para o seu sistema operacional (Windows, Mac ou Linux).
- Siga as instruções de instalação. Você pode precisar reiniciar o computador.

IMPORTANTE: Você pode pesquisar como instalar o Docker diretamente no seu sistema operacional, sem o Docker Desktop. O Docker Desktop possui restrições comerciais de licença de uso em ambientes corporativos.

Após a instalação, abra um terminal no Linux (ou PowerShell, no Microsoft Windows) e execute o comando de verificação:

```
docker --version
```

Uma saída esperada (exemplo), seria: Docker version 20.10.17, build 100c701

2. Instalação do Trivy

Neste momento, será necessário instalar a ferramenta de escaneamento, o Trivy. Dentre as opções abaixo, escolha a instrução para o seu sistema operacional adotado:

Para macOS (usando Homebrew)

```
# Atualiza o Homebrew (boa prática)
brew update
# Instala o Trivy
brew install trivy
```

Para Linux (Debian/Ubuntu)

Requer-se adicionar o repositório oficial do Trivy para que ele seja gerenciado e atualizado pelo utilitário apt. Para tanto, no Terminal do Linux:

```
# 1. Instala dependências necessárias
sudo apt-get install wget apt-transport-https gnupg lsb-release

# 2. Adiciona a chave GPG do repositório do Trivy
wget -qO - https://aquasecurity.github.io/trivy-repo/deb/public.key | sudo apt-key add -

# 3. Adiciona o repositório do Trivy à sua lista de fontes
echo "deb https://aquasecurity.github.io/trivy-repo/deb $(lsb_release -sc) main" | sudo tee /etc/apt/sources.list.d/trivy.list

# 4. Atualiza o gerenciador de pacotes e instala o Trivy
sudo apt-get update
sudo apt-get install trivy
```

Para Linux (RHEL/CentOS)

O processo é similar ao Ubuntu/Debian, mas usando yum/dnf. Para tanto, no Terminal do Linux:

```
# 1. Adiciona o repositório
sudo rpm -ivh https://github.com/aquasecurity/trivy/releases/download/v0.51.1/trivy_0.51.1_Linux-64bit.rpm
# Nota: Verifique a versão mais recente no GitHub do Trivy se esta falhar

# 2. Instala via dnf (ou yum)
sudo dnf install trivy
```

No Microsoft Windows (usando Scoop ou Chocolatey), adotando o PowerShell:

Via Scoop (recomendado):

```
scoop install trivy
```

Via Chocolatey:

```
choco install trivy
```

2. Scan da Imagem da Imagem de Contêiner

Primeiro, requer-se verificar se o Trivy foi instalado corretamente:

Verificando a versão

```
trivy --version
```

Uma saída esperada (de exemplo), seria: Version: 0.68.1.

Neste momento será necessário realizar o download de uma imagem para realizar o scan. Para tanto, será usada uma versão antiga e intencionalmente não corrigida do nginx (um servidor Web).

Realiza o download da imagem do nginx na versão 1.20.0 (vulnerável) do Docker Hub

```
docker pull nginx:1.20.0
```

Com este comando acima, o Docker irá baixar as camadas da imagem do nginx para realizar o scan.

O primeiro comando, abaixo, é utilizado para realizar o scan da imagem e apresentar todas as vulnerabilidades encontradas.

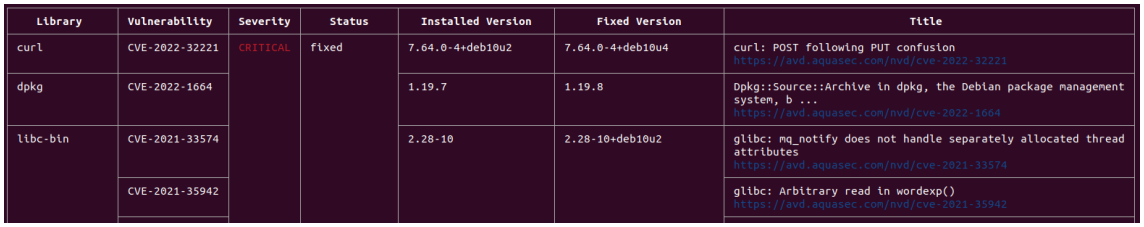
Diz ao Trivy para escanear uma 'imagem' (image) chamada 'nginx' com a 'tag' (versão) '1.20.0'

```
trivy image nginx:1.20.0
```

Quando terminar, um resultado possível será uma lista de vulnerabilidades no formato de uma tabela, com as seguintes informações:

- **Library**: O pacote de software com a falha (ex: openssl, zlib).
- **Vulnerability ID**: O identificador universal da falha (ex: CVE-2022-1292).
- **Severity:** A gravidade (CRITICAL, HIGH, MEDIUM, LOW, UNKNOWN).
- **Installed Version**: A versão vulnerável na imagem.
- **Fixed Version**: A versão que corrige a falha.

A figura abaixo, representa a saída:



Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
curl	CVE-2022-32221	CRITICAL	fixed	7.64.0-4+deb10u2	7.64.0-4+deb10u4	curl: POST following PUT confusion https://avd.aquasec.com/nvd/cve-2022-32221
dpkg	CVE-2022-1664			1.19.7	1.19.8	Dpkg::Source::Archive in dpkg, the Debian package management system, b ... https://avd.aquasec.com/nvd/cve-2022-1664
libc-bin	CVE-2021-33574			2.28-10	2.28-10+deb10u2	glibc: mq_notify does not handle separately allocated thread attributes https://avd.aquasec.com/nvd/cve-2021-33574
	CVE-2021-35942					glibc: Arbitrary read in wordexp() https://avd.aquasec.com/nvd/cve-2021-35942

Para **obter o resultado somente das vulnerabilidades de gravidade técnica definida**, use o comando abaixo:

```
trivy image --severity HIGH,CRITICAL nginx:1.20.0
```

Parte das vulnerabilidades pode ainda não ter uma correção (um patch) disponível. **Pode-se verificar somente aquelas vulnerabilidades com a correção disponível** para de fato realizar a remediação:

```
trivy image --ignore-unfixed nginx:1.20.0
```

Também, é possível **salvar o resultado em formato HTML**, para ser analisado em um Browser ou compartilhado. Para tanto, adote o comando abaixo:

```
trivy image --format template --template
"@/usr/local/share/trivy/templates/html.tpl" -o trivy-
report.html nginx:1.20.0
```

No caso acima, deve-se ficar atendo ao caminho (path) definido para a diretiva –template. Para saber o caminho correto no seu sistema operacional Linux, faça:

```
$ sudo apt install locate

$ updatedb

$ locate html.tpl
```

Então, use o caminho (path) do retorno do comando anterior. Certifique-se que html.tpl esteja dentro de um diretório do Trivy, caso haja outros arquivos com o mesmo nome.

CONCLUSÃO

Você completou o procedimento de scan de imagens de contêineres utilizando o Trivy.